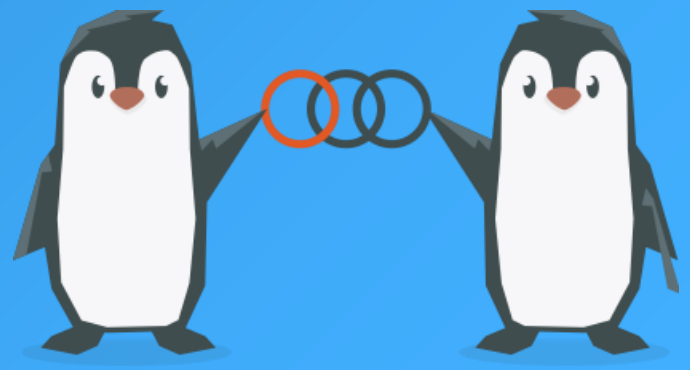
Open Source based Supply Chain Management at Scale

OpenChain and Friends 2026
2026-03-24 14:05-14:25

THE LINUX FOUNDATION

OPENCHAIN



Intro

Marcel Kurzmann

Open Source Consultant @ Bosch Digital and member of the OSPO

Nikola Babadzhanov

Open Source Consultant @ Bosch Digital and member of the OSPO

OPENCHAIN

The Open-Source Tooling Group

Open Source Tooling Group

We are focused on building an OSS compliance toolchain ecosystem with OSS tools as an OSS project. To accomplish this, we:

- Use existing tools, which all remain independent
- Provide the concepts and glue code to hook them easily together or to be integrated easily in any existing environment
- Provide reference workflows, that can be easily adapted to serve own needs
- Provide the tools hooked together as a turnkey reference toolchain that can be used without fees by anybody

* The tools named in this picture are just examples

Join us in creating a new era of OSS compliance

Mailing List: oss-based-compliance-tooling@groups.io

Subscription page: https://groups.io/g/oss-based-compliance-tooling

Online meetings: Bi-weekly - Invitations are send to the mailing list

Website: https://oss-compliance-tooling.org/

Github: https://github.com/Open-Source-Compliance/Sharing-creates-value

The Open Source Tooling Group 2024 License: CC-BY-SA-4.0 Oliver Fendt

From https://oss-compliance-tooling.org/

THE LINUX FOUNDATION OPENCHAIN

Eclipse Apoapsis Guidance - in a nutshell

- **Problem-Space** ➡ **Generic Architecture** ➡ **Blueprints**

Former times:

Use Case

Hardly documented

???

unaligned wording

hard to map

Several Solutions

Solution 1
Solution 1a
Solution 2
...

hard to compare

With Apoapsis Guidance:

Use Case Collections

Standard Building Blocks *From the Tooling Work Group*

Standardized Blueprint Descriptions

Landing Zones for Solutions

THE LINUX FOUNDATION

OPENCHAIN

Eclipse Apoapsis Guidance - example

Use Case

- **Problem-Space** **Generic Architecture** **Blueprints**

As a Software Development Team I want a continuous development monitoring so that I get fast feedback about the status of non-functional requirements in my project.

documented

THE LINUX FOUNDATION

OPENCHAIN

Eclipse Apoapsis Guidance - example

Use Case

- **Problem-Space** ➡ **Generic Architecture**

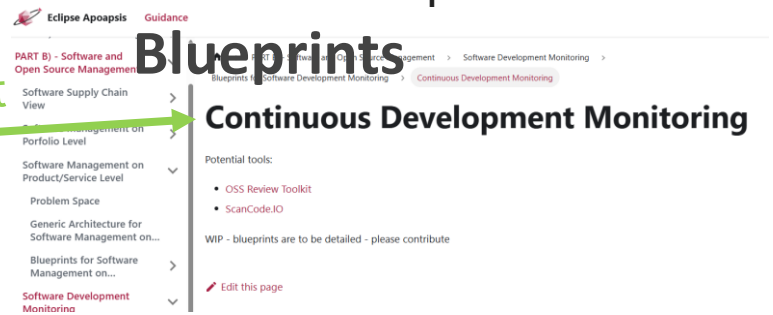
Standardized Blueprint Descriptions

Blueprints

Mapped to blueprint

As a Software Development Team I want a continuous development monitoring so that I get fast feedback about the status of non-functional requirements in my project.

documented



THE LINUX FOUNDATION

OPENCHAIN

Eclipse Apoapsis Guidance - example

Use Case

- **Problem-Space** ➡ **Generic Architecture** ➡ **Blueprints**

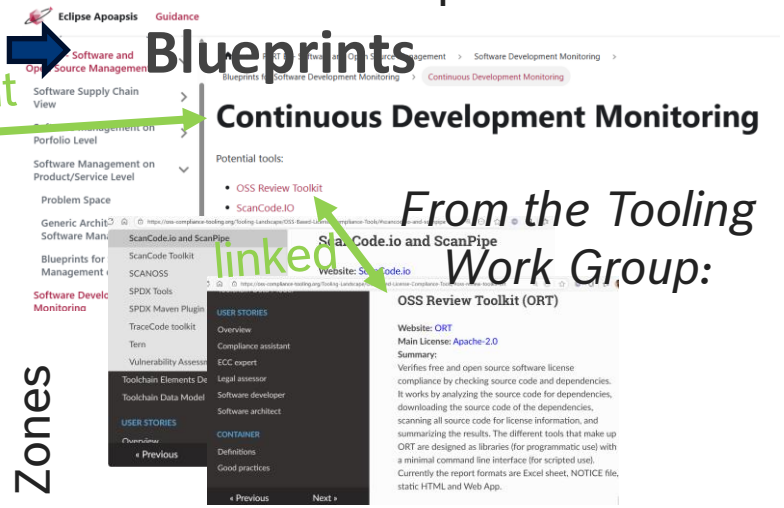
Standardized Blueprint Descriptions

Mapped to blueprint

As a Software Development Team I want a continuous development monitoring so that I get fast feedback about the status of non-functional requirements in my project.

documented

linked



From the Tooling Work Group:

Landing Zones

THE LINUX FOUNDATION

OPENCHAIN

Eclipse Apoapsis Guidance - example

Use Case

- **Problem-Space** ➡ **Generic Architecture** ➡ **Blueprints**

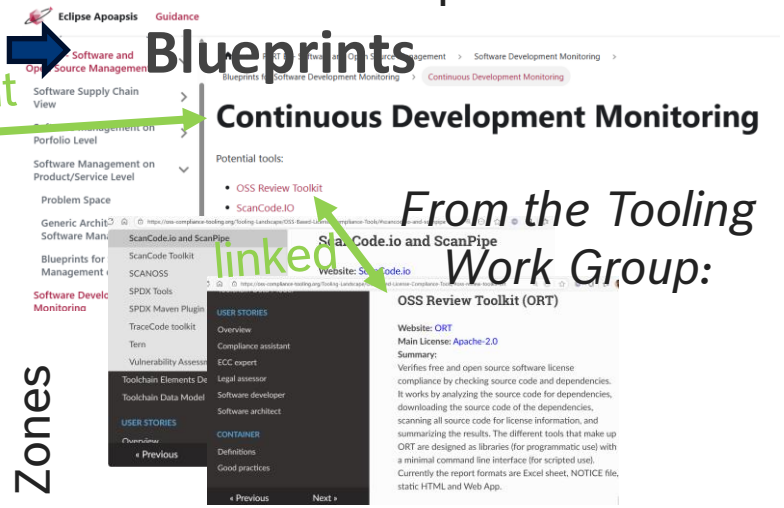
Standardized Blueprint Descriptions

Mapped to blueprint

As a Software Development Team I want a continuous development monitoring so that I get fast feedback about the status of non-functional requirements in my project.

documented

linked



From the Tooling Work Group:

Landing Zones

Commercial Solutions

With Apoapsis Guidance:
to enable a complete picture

THE LINUX FOUNDATION

OPENCHAIN

Eclipse Apoapsis Guidance - example

Use Case

- **Problem-Space**

Standard Building Blocks
From the Tooling Work Group

Generic Architecture

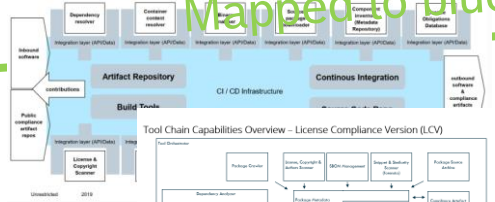
Standardized Blueprint Descriptions

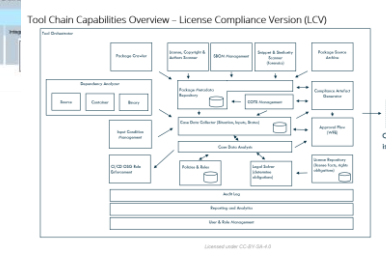
Blueprints

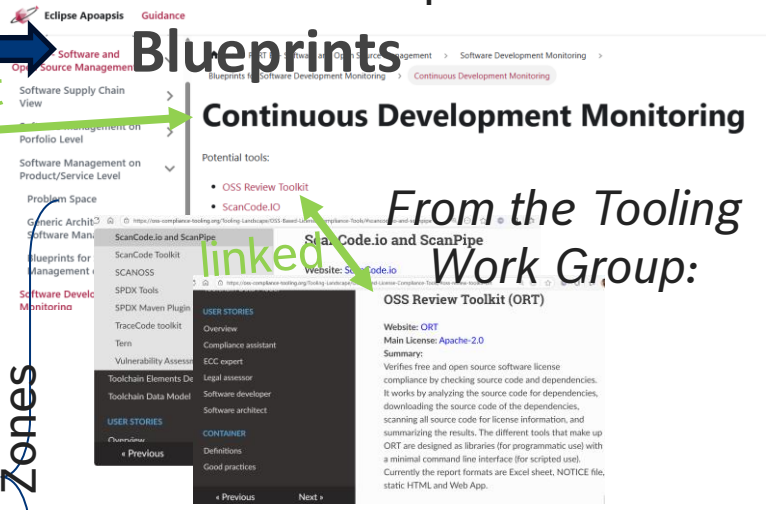
As a Software Development Team I want a continuous development monitoring so that I get fast feedback about the status of non-functional requirements in my project.

documented

Mapped to blueprint







linked

From the Tooling Work Group:

comparable

Landing Zones

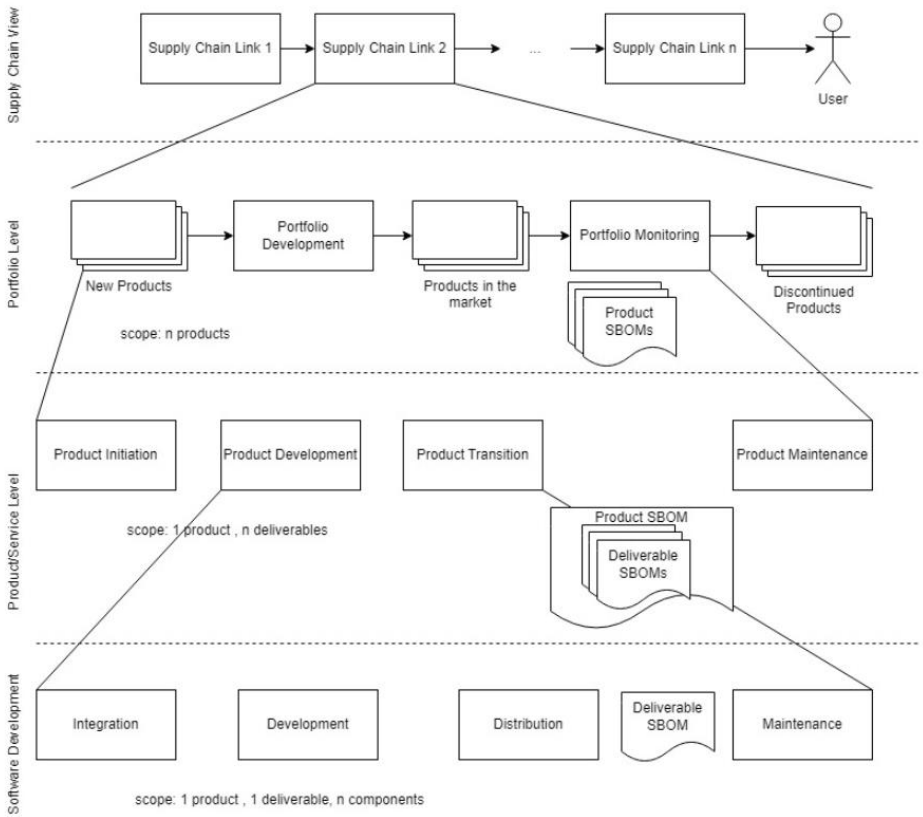
Commercial Solutions

With Apoapsis Guidance:
to enable a complete picture

THE LINUX FOUNDATION

OPENCHAIN

The Eclipse Apoapsis Main structure



Source: https://eclipse-apoapsis.github.io/guidance/docs/part_B_software_management/

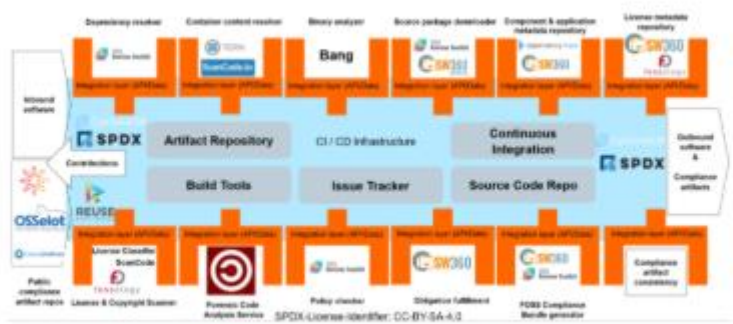
OPENCHAIN

The Open-Source Tooling Group

Open Source Tooling Group

We are focused on building an OSS compliance toolchain ecosystem with OSS tools as an OSS project. To accomplish this, we:

- Use existing tools, which all remain independent
- Provide the concepts and glue code to hook them easily together or to be integrated easily in any existing environment
- Provide reference workflows, that can be easily adapted to serve own needs
- Provide the tools hooked together as a turnkey reference toolchain that can be used without fees by anybody



* The tools named in this picture are just examples

Join us in creating a new era of OSS compliance

Mailing List: oss-based-compliance-tooling@groups.io

Subscription page: https://groups.io/g/oss-based-compliance-tooling

Online meetings: Bi-weekly - Invitations are send to the mailing list

Website: https://oss-compliance-tooling.org/

Github: https://github.com/Open-Source-Compliance/Sharing-creates-value

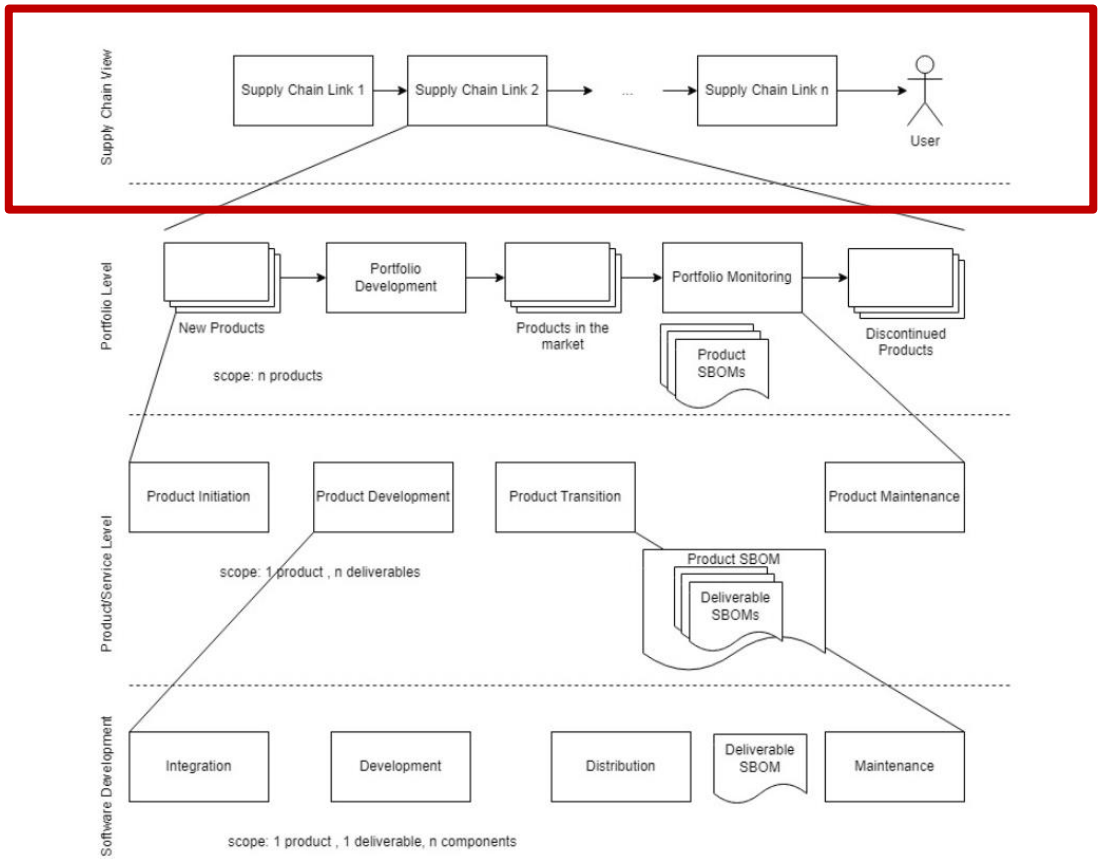
License: CC-BY-SA-4.0
Oliver Fendt

From https://oss-compliance-tooling.org/

THE LINUX FOUNDATION

OPENCHAIN

The Eclipse Apoapsis Main structure



Source: https://eclipse-apoapsis.github.io/guidance/docs/part_B_software_management/

Problem Space

- How do we check if our tools are really working correctly?
  - Different tools for the same task
  - Reference for content discussions concerning license and copyrights (automated policies!)
  - Reference for testing vulnerability monitoring
- How do we ensure compatibility between the tools and processes?
  - Continuous development of exchange formats and regulations
  - Legacy tooling / integration in existing infrastructure
  - Testing of complex SBOM setups with the Software Composition Analysis (SCA)- Tools
  - Regular „plugfests“ to evaluate SCA-tools (~once a year) only superficial and hard to compare
- How do we ensure the necessary competences?
  - Training and show-casing of complex setups?
  - Re-production of Tool-behavior in special situations

Problem Space

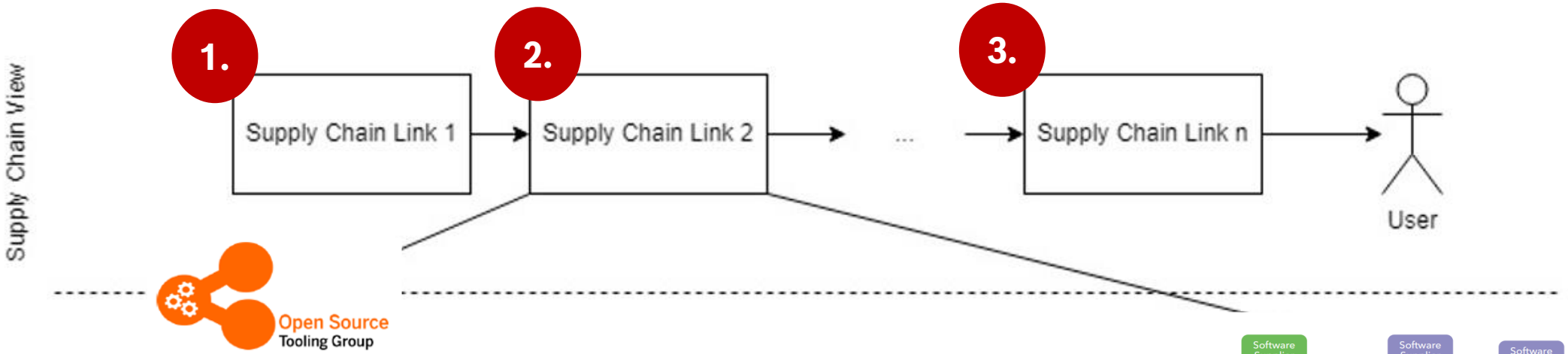
- How do we check if our tools are really working correctly?
- How do we ensure compatibility between the tools and processes?
- How do we ensure the necessary competences?

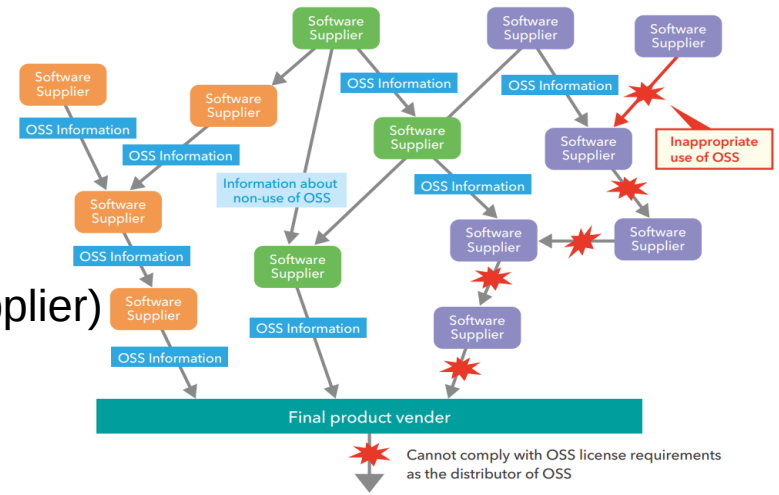
Use Case

As a [Community] for Supply Chain Risk Management we want to have Supply Chain Simulation so that we can have a public reference for publicly showcasing and training special supply chain cases that involve more than one link in the supply chain.

Idea

Establish a publicly available supply chain simulation





1. Software vendor (Dummy-repository simulating upstream)
2. Software Integrator (OSS based SCA tooling simulating a SW supplier)
3. Manufacturer (Open Source Portal/Database simulating an OEM)

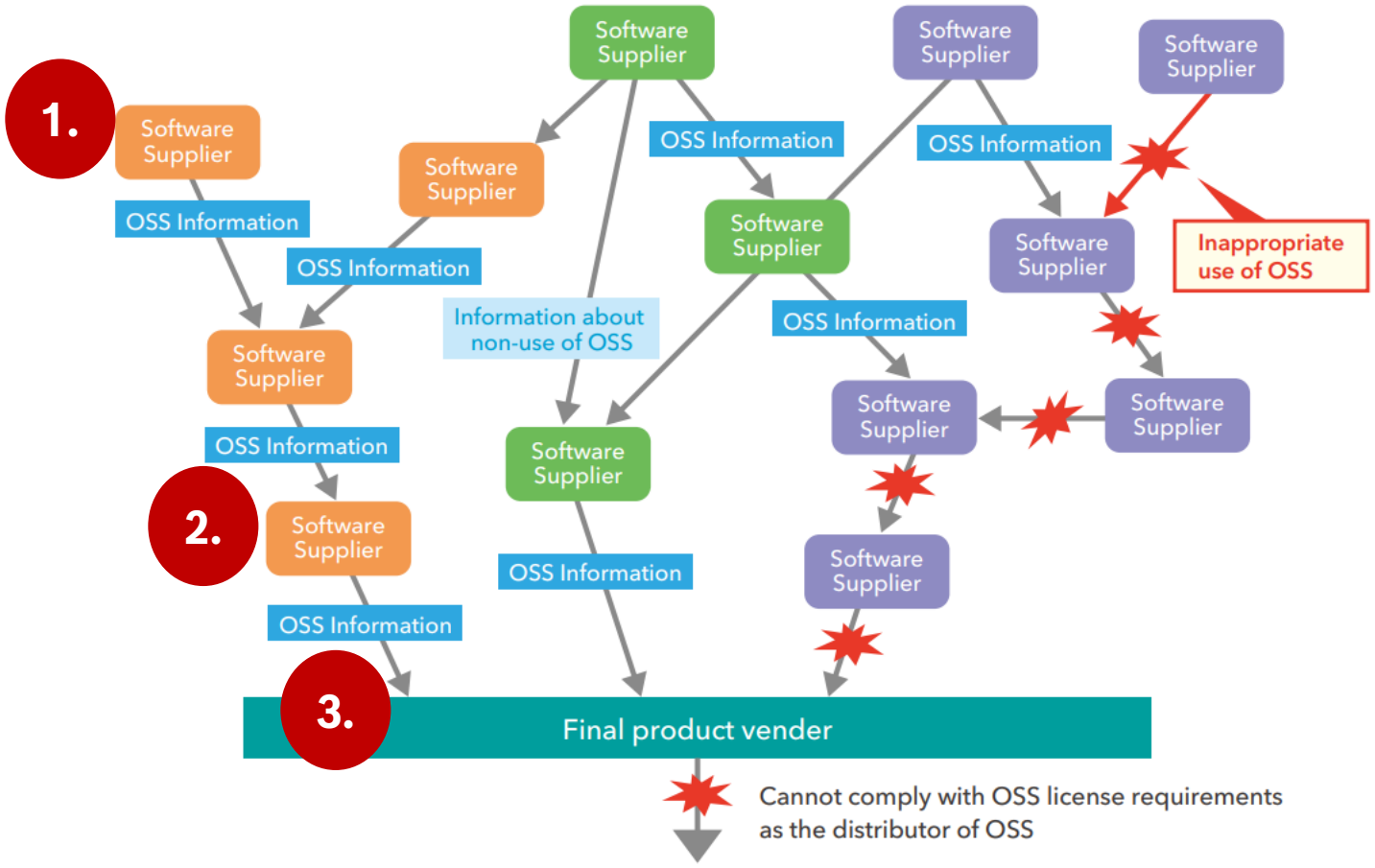
THE LINUX FOUNDATION

OPENCHAIN

Recap

Supply Chain

Different links in the „chain“
Different contexts
Different use cases
Different problem spaces

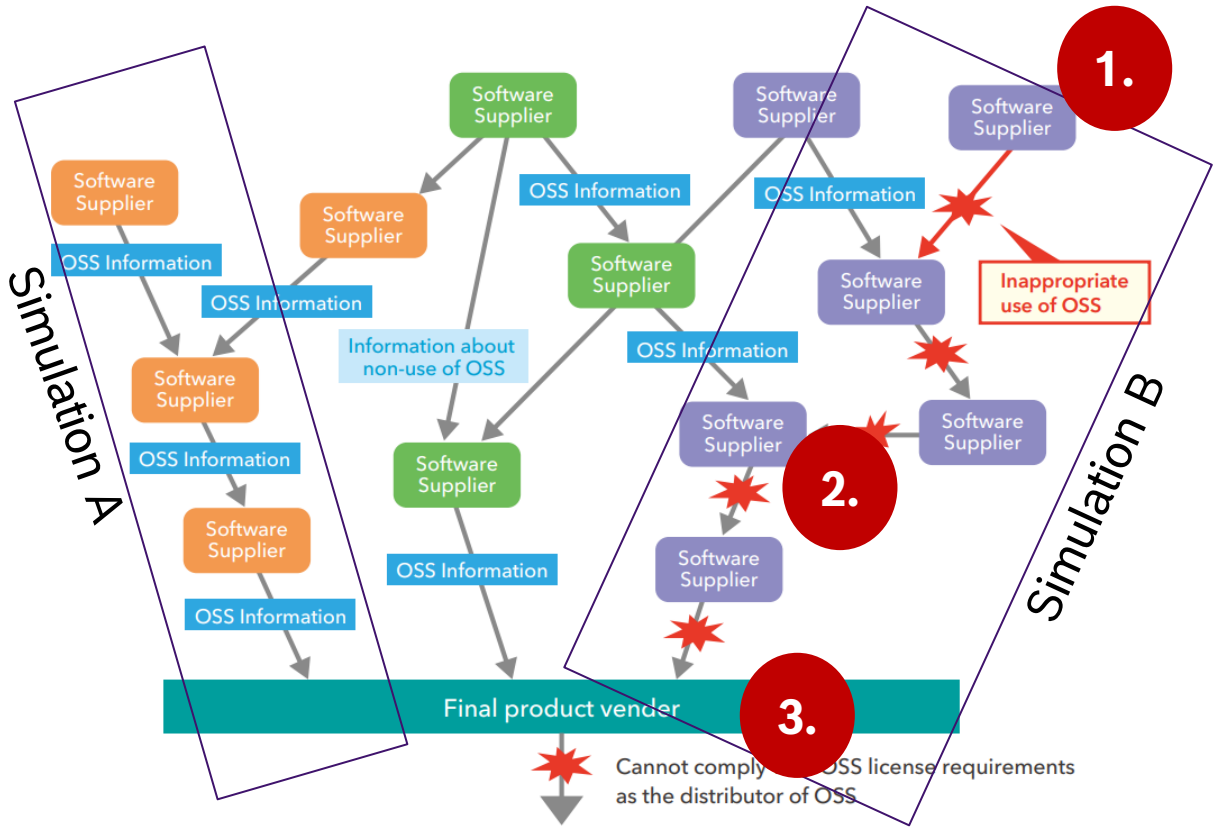


Source: https://github.com/OpenChain-Project/Reference-Material/blob/master/Education-For-Suppliers/Supplier-Education-Leaflet/supply-chain-education-leaflet-version-1-2019/OpenChain-2.1-Edition/en/supplier-leaflet-en.pdf

THE LINUX FOUNDATION
OPENCHAIN

Idea

Establish a publicly available supply chain simulation!



Benefits:

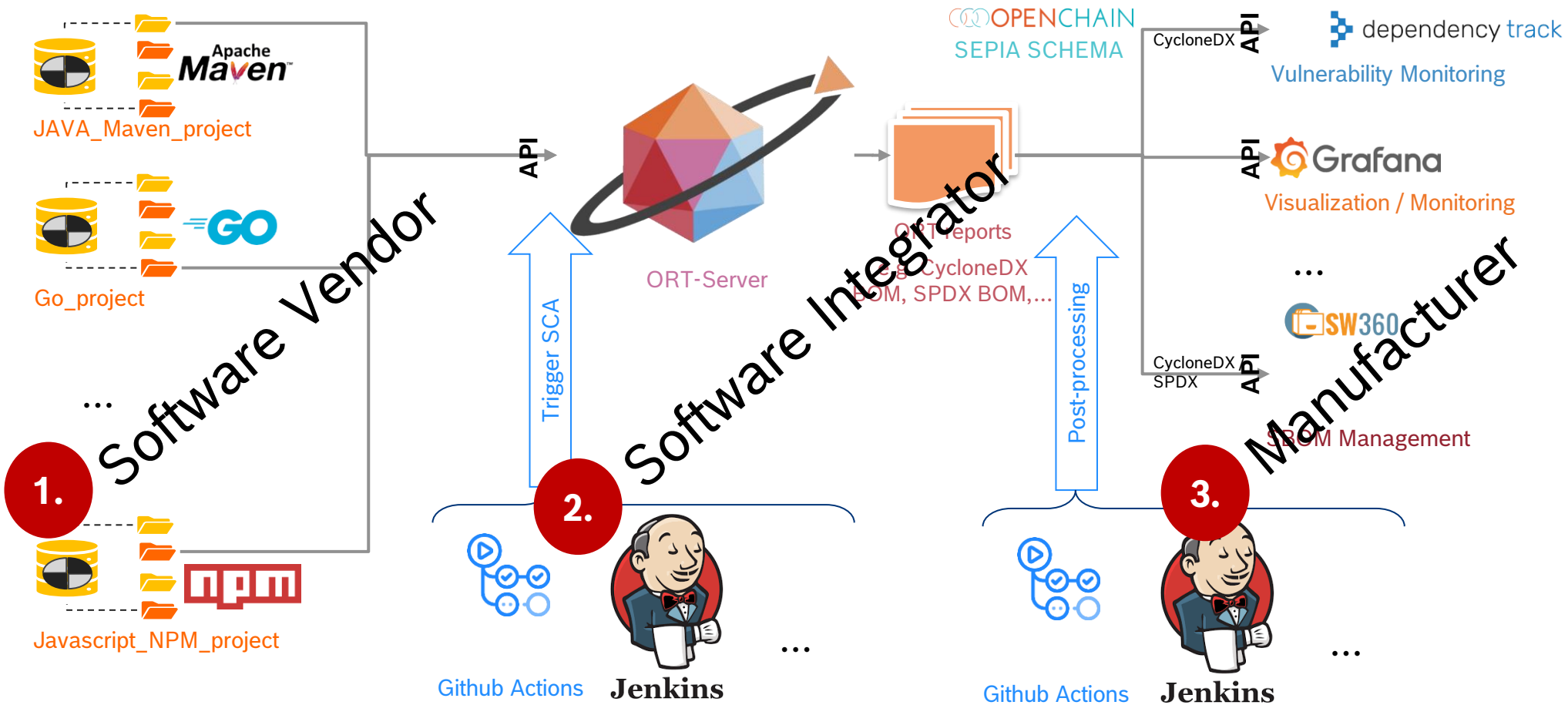
- Use for trainings
- Use for showcases
- Use for testing the tool chain / infrastructure
- Reference for interface discussions
- …

Source: https://github.com/OpenChain-Project/Reference-Material/blob/master/Education-For-Suppliers/Supplier-Education-Leaflet/supply-chain-education-leaflet-version-1-2019/OpenChain-2.1-Edition/en/supplier-leaflet-en.pdf

Supply Chain SBOM Reference Tooling

Setup End-to-end (principle)

One of potential several blueprints



Standardized Blueprint Descriptions

Blueprint Documentation

Eclipse Apoapsis Guidance

Intro

PART A) Context Knowledge

PART B) - Software and Open Source Management

Software Supply Chain View

Problem Space

Generic Software Supply Chain Architecture

Software Supply Chain Blueprints

Public available supply chain simulation based on Open...

Public available supply chain simulation

Software Management on Porfolio Level

Software Management on Product/Service Level

Software Development Monitoring

Get involved

Basic Simulation Showcase Setup

The basic simulated supply chain is meant to be as simple as possible and consists of three parts:

1. Part that simulates a original Software vendor (e.g. an upstream Open Source Project) with a code repository.
2. Part that simulates a Software integrator (e.g. a Software supplier that re-uses Open Source components in a derivative work) that ships a combined work and provides an SBOM
3. Part that simulates a manufacturer that gets several SBOMs from various suppliers and needs to manage them

Part 1 - Software vendor

- A) The simulation uses the Dummy Repositories from the OpenChain Tooling group
- B) The dependency-tree can be shown in the Github Dependency graph
  Hint: You can use a local ORT-installation as alternative to create the dependency graph.

for simplicity Github with its onboard equipment was used instead of insisting on complete open source setup - so it is publicly available but not Open Source => Improvement potential

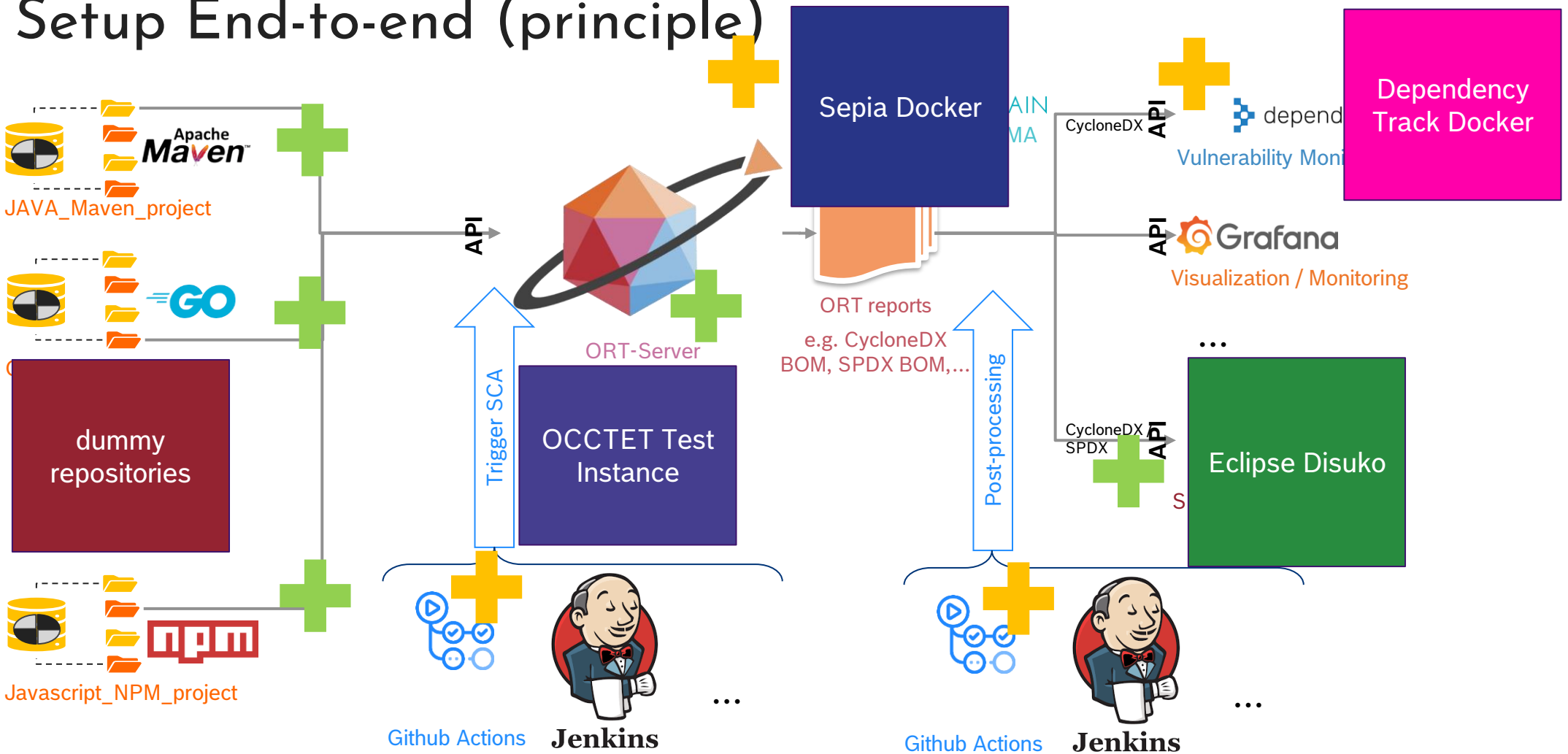
Concrete example used for:

- A) https://github.com/Open-Source-Compliance/JAVA_Maven-Dummy
- B) https://github.com/Open-Source-Compliance/JAVA_Maven-Dummy/network/dependencies

Supply Chain SBOM Reference Tooling

Setup End-to-end (principle)

One of potential several blueprints



The main actors

The software vendor 1.

- 3-4 dummies currently available
  - Issues for improvement: additional dummies + blueprint based on OSS IDE instead of VS Code
  - Communication in our meetings and via issues: https://github.com/Open-Source-Compliance/Sharing-creates-value/issues

Part 1 - Software vendor

- A) The simulation uses the Dummy Repositories from the OpenChain Tooling group
- B) The dependency-tree can be shown in the Github Dependency graph
  for simplicity Github with its onboard equipment was used instead of insisting on complete open source setup - so it is publicly available but not Open Source => Improvement potential
  Hint: You can use a local ORT-installation as alternative.

Concrete example used for:

- A) https://github.com/Open-Source-Compliance/JAVA_Maven-Dummy
- B) https://github.com/Open-Source-Compliance/JAVA_Maven-Dummy/network/dependencies

Hint: You can vary the simulation by using a different available dummy-repository.

Dummy Repositories

dummy repositories

Object under Analysis
OpenChain Tooling Group
Dummy Repositories

Contact:

- Nikola Babadzhanov, Marcel Kurzmann

Landing page:

- https://github.com/Open-Source-Compliance/Sharing-creates-value/blob/master/Tooling-Landscape/Dummy_Repositories/README.md

Benefits:

- Base for benchmarking
- Base for showcasing and testing
- Public collaboration on interesting test-/showcases
- Core maintained by upstream

Details:

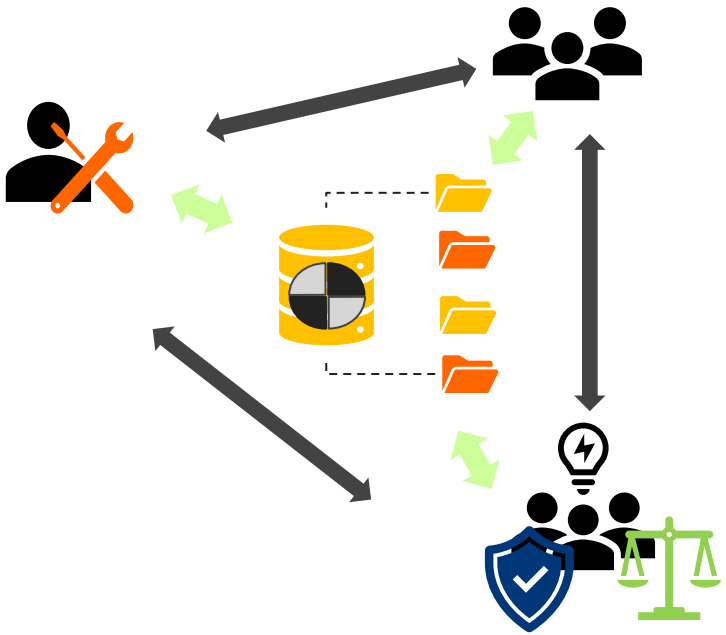
- Repos need to be a little bit more complex than „Hello World“ and contain dependencies
- https://www.youtube.com/watch?v=zJEg2qitPtE

Public Dummy Repositories - Benefits

- Benefits for tool vendors and service providers
  - Use as base for testing (and „debugging“)
  - Use for benchmark
  - Reproduce irregular behavior

- Benefits for Users
  - Use for Installation check for SCA tools
  - Reproduce irregular behavior of the used tooling
  - Provide real showcases for benchmark (non-fair weather)

- Benefits for expert community
  - Use as publicly available reference and benchmark for available tools
  - Use as base for trainings/education
  - Reproduce interesting cases by injecting real dependencies with known issues (beyond mere theory)

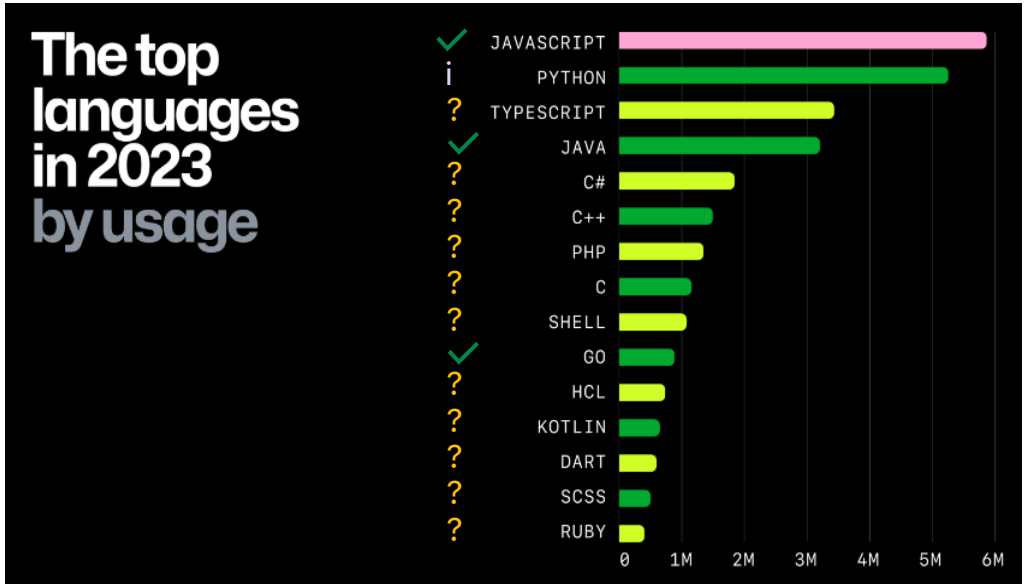


=> e.g. for automated policies (in the rule engines)

Update on setup

- First repository forked for Go: https://github.com/Open-Source-Compliance/Go-Dummy
- Second repository forked for Java MAVEN: https://github.com/Open-Source-Compliance/JAVA_Maven-Dummy
- Third repository forked for Javascript NPM : https://github.com/jenkins-docs/simple-node-js-react-npm-app

Kudos to the Jenkins Documentation team for providing the base!



From Octoverse report; Source: https://github.blog/2023-11-08-the-state-of-open-source-and-ai/

Outlook:

- Further prospect identified in
  - https://github.com/jenkins-docs/simple-python-pyinstaller-app

Precondition: Maintained by upstream project!

We need YOU!!! => Please help us finding upstream project that we could use as base for dummies to cover the whole landscape

The main actors

The software integrator 2.

- OCTTET ORT Test-Server https://ort-server.occtet.eu/ can be used
  - UI / Login is already functional, first scans were running
  - Communication with Sebastien via Matrix: https://matrix.to/#/#apoapsis:matrix.eclipse.org

Part 2 - Software integrator

- A) The simulation uses a "demo" branch in the Dummy Repository to simulate a modification
- B) The simulation uses an instance of the ORT-Server as ORT-based SCA tooling to analyze the repository and generate the SBOM from the Dummy Repository
  Hint: You can use a local ORT-installation as alternative.
- C) The ORT-report provides already transparency about all dependencies and findings
- D) The ORT-reporter generates the SBOM in CycloneDX and SPDX for further processing

Concrete example used for:

- A) https://github.com/Open-Source-Compliance/JAVA_Maven-Dummy/tree/demo/case_001_vulnerability => adds a vulnerable dependency
- B) WIP => will use a Sandbox Org in the public OCTETT Test-Server
- C) WIP => the report will be publicly available in the public OCTETT Test-Server

Supply Chain SBOM Reference Tooling

Software Composition Analysis

OCTETT ORT
Test -Server

Software
Composition
Analysis
Eclipse Apoapsis /
OSS Review Toolkit
ORT-Server / ORT

Contact:

- Sebastien Heurtematte
  https://matrix.to/#/#apoapsis:matrix.eclipse.org

Landing page / „Managed Service“:

- https://eclipse-apoapsis.github.io/ort-server/
- https://ort-server.occtet.eu/

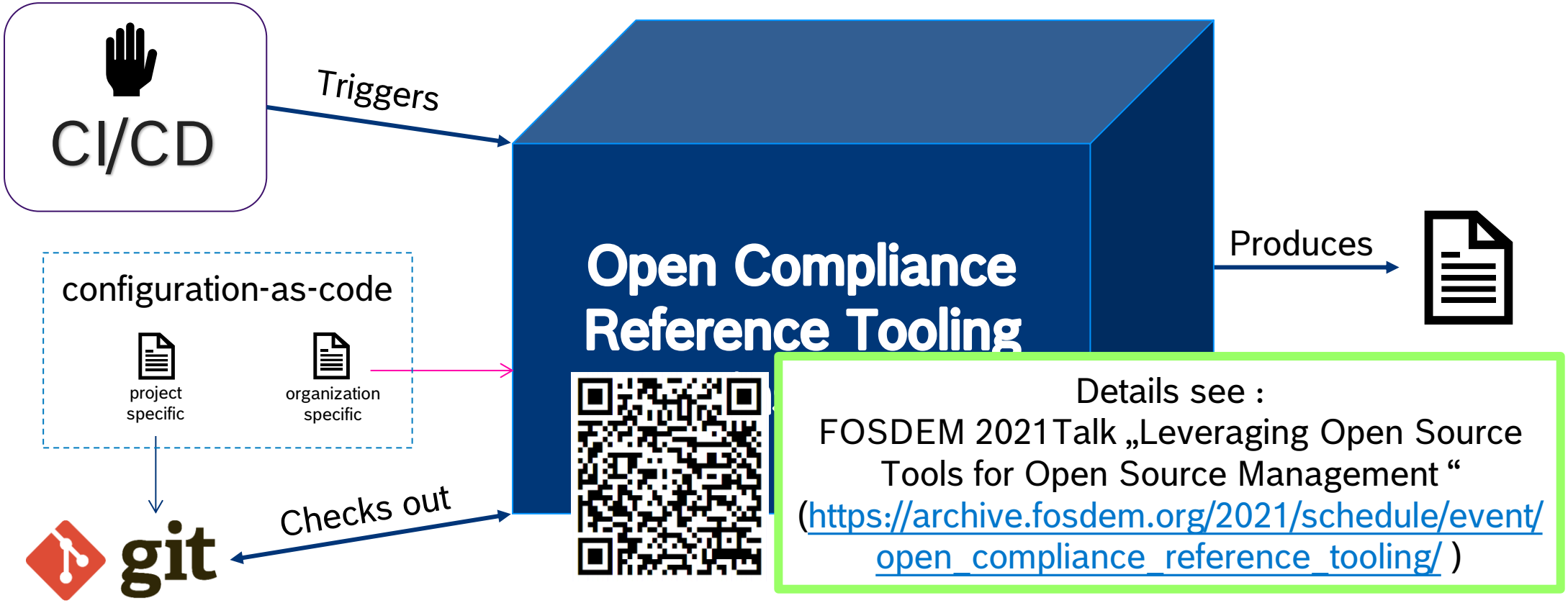
Benefits:

- Wrapper / Orchestrator
- Standardized automated processing
- Configuration as code
- SBOM generation
- Server with API and management UI

Details:

- https://openchainproject.org/news/2025/07/02/webinar-project-occtet

Central pipeline - How does it work?



[1] https://freebiesupply.com/logos/git-logo/

Open Compliance Reference Tooling

OSS Review Toolkit as virtual conveyor belt

	determine the dependencies of projects and their metadata	fetch all source code of the projects and their dependencies	use configured source code scanners to detect license / copyright findings	retrieve security advisories for used dependencies from configured vulnerability data services	evaluate license / copyright findings against customizable policy rules and license classifications	present results in various formats such as visual reports
	abstracting which package managers or build systems are actually being used	abstracting which Version Control System (VCS) or other means are used to retrieve the source code.	abstracting the type of scanner.	abstracting the data source for vulnerability data	abstracting the rule set defining the policy rules and license classifications	abstracting the customized representation
Selection of available Open Source Examples:	SPDX https://spdx.dev/ npm PyPi ...	git https://git-scm.com/	ScanCode https://github.com/nexB/scancode-toolkit ClearlyDefined https://clearlydefined.io/	VulnerableCode https://github.com/nexB/vulnerablecode	doubleOpen() https://github.com/doubleopen-project/policy-configuration	SPDX https://spdx.dev/ https://cyclonedx.org/ AsciiDoc https://asciidoc-py.github.io/

More details see https://github.com/oss-review-toolkit/ort/

The main actors

The manufacturer 3.

- Dependency Track does not provide a public test server, but Docker setup may be used
- For sw360 Helio provided a public test-server that can be used: https://sw360.heliocastro.info/
  - UI / Login is already functional, SBOM could be imported
  - Communication with Helio via Slack: https://app.slack.com/client/T67JF82EQ/C68C2RYS3

Part 3 - Manufacturer

- A) the simulation uses the SBOM provided in 2 D) as input to simulate a delivery from a supplier
  Hint: The delivery of Software/Binaries is actively ignored for simplification.
- B) the simulation uses a local OWASP DependencyTrack-installation as Vulnerability Monitoring Dashboard for incoming supplier SBOMs. A project is created and the CycloneDX SBOM is uploaded. The analysis provides transparency about all dependencies and findings.
- C) Potential extensions:
  - the simulation uses an instance of Eclipse sw360 for tracking all Software Components
  - the simulation uses an instance of Eclipse disuko as SBOM portal

Concrete example used for:

- A) see 2 D)
- B) WIP => the SBOMs will be publicly available in a public sw360 test-server

Supply Chain SBOM Reference Tooling

Vulnerability Monitoring

Dependency Track Docker

Vulnerability Monitoring

OWASP

Dependency Track

Contact:

- Dependency Track Team

Landing page/Managed service:

- https://dependencytrack.org/
- Outlook: https://sbom.eclipse.org/

Benefits:

- Dashboard for Projects/Products
- Dashboard for Vulnerabilities
- Continuous Monitoring of static SBOMs
- Vulnerability Audit UI

Details:

- https://www.youtube.com/watch?v=VpNnxpIBBk0

Supply Chain SBOM Reference Tooling

SBOM Validation

Sepia

SBOM Validation

OpenChain SBOM Workgroup
SEPIA

Contact:

- Rakesh Prabhakaran, Nikola Babazhanov

Landing page :

- https://github.com/OpenChain-Project/SBOM-sg-SEPIA

Benefits:

- Validation of SBOM against defined scheme
- Merging of SBOMs
- SPDX/CycloneDX/SPDX conversion

Details:

- https://www.youtube.com/watch?v=3CF6adYWCtE

Summary

- Turnkey reference toolchain that can be used without fees by anybody
- You can try all of this at home
- Open Source Community around tooling is there for helping you in getting engaged

- Please reach out to us in case you even need more support for company internal instance
  - We can match you with people that can provide commercial services around the Open Source solutions

- OpenChain Tooling Work Group meetings every 1st (EU/Asia) and 3rd (US/EU) Wednesday
- https://groups.io/g/oss-based-compliance-tooling

Contributions on all levels welcome!

THE LINUX FOUNDATION

OPENCHAIN